

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering
ASSESSMENT TOOL 3 – INCIDENT RESPONSE (MONITORING & MITIGATION)

Course Code:	CSA5802	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 3
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Develop Incident Response Plan, Analyze Security Monitoring Dashboard, Recommend Mitigation Strategies and Technical Justification.		
Student Name:	Krithika M	Reg. No.:	192521385
Section / Batch:	B.Tech - IT	Date:	

Instructions to Students

- Develop an incident response plan based on the given security incident scenario and identified findings.
- Analyze the provided security monitoring dashboard, alerts, logs and indicators to determine incident status and affected assets.
- Recommend prioritized mitigation strategies that directly address the identified threats, vulnerabilities and incident impact.
- Provide clear technical justification for each major response and mitigation decision using evidence from the scenario.
- Present the response plan, dashboard analysis and recommendations clearly and professionally within the prescribed submission format.

Question Type	Focus Area	Questions	Marks
INCIDENT RESPONSE	Monitoring & Mitigation	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

TELEMEDICINE SECURITY INCIDENT RESPONSE AND MITIGATION PLAN

Incident Scenario: Security alerts show repeated unauthorized attempts to access Electronic Health Records (EHRs) through a doctor account. The incident must be analyzed using the monitoring dashboard, alerts, authentication logs, EHR audit records, session information and other available indicators before reaching conclusions.

1. Dashboard and Alert Analysis

The security monitoring dashboard indicates repeated suspicious EHR access activity associated with a doctor account. Because EHRs contain sensitive patient information, the incident should be treated as **active and high priority** until investigation proves the activity was legitimate.

- Repeated failed authentication or EHR access attempts involving the doctor account.
- Possible successful access after repeated failures.
- Unusual login times, devices, network sources or concurrent sessions.
- Attempts to access patient records outside approved clinical responsibilities.
- Authorization-denied events or abnormal increases in records accessed.
- Alerts generated by the telemedicine application, identity system, EHR platform or centralized monitoring system.

Incident Status: Suspected account misuse or attempted compromise.

Priority: High.

Immediate Objective: Contain suspicious access while preserving evidence.

2. Affected Assets

- Doctor account, credentials and authentication factors.
- Telemedicine application and identity services.
- Electronic Health Record database and patient information.
- Active sessions, authentication tokens and connected devices.
- Role and permission configurations.
- Audit logs and security monitoring systems.
- Patient privacy, confidentiality, service continuity and organizational reputation.

The EHR system is the most critical asset because unauthorized access can expose confidential patient information and cause significant technical and operational impact.

3. Incident Sequence and Evidence-Based Findings

- The doctor account generates repeated authentication or EHR access events.
- Security controls identify repeated failed, denied or abnormal attempts.
- Alerts appear on the security monitoring dashboard.
- Authentication logs, EHR audit logs and session records are reviewed.

- The investigation determines whether any attempt succeeded and which records were requested.
- The account and associated sessions are treated as potentially compromised until evidence confirms otherwise.

The investigation must avoid unsupported assumptions. Credential theft, for example, should only be considered confirmed when supported by authentication, device, session or other evidence.

4. Root-Cause Reasoning

The observed pattern suggests possible misuse or compromise of the doctor account. The root cause should be determined by linking suspicious events to the technical conditions that enabled them. Possible contributing conditions include weak or exposed credentials, inconsistent MFA enforcement, excessive session duration, failure to revoke suspicious sessions, overly broad permissions, shared accounts or insufficient monitoring.

Logical sequence: repeated suspicious activity → correlation of authentication and EHR logs → identification of abnormal behavior → examination of authentication, session and authorization controls → confirmation of the contributing weakness.

For example, repeated failed logins followed by successful access from an unfamiliar device would support possible credential compromise. Successful access to records outside the doctor's authorized scope would indicate an authorization or role-control weakness.

5. Risk Assessment

Risk Factor	Assessment	Technical / Operational Impact
Likelihood	High	Repeated suspicious attempts indicate active targeting or account misuse.
Severity	High	EHR systems contain highly sensitive patient information.
Confidentiality Impact	High	Unauthorized disclosure of patient records may occur.
Integrity Impact	Medium to High	Excessive permissions could allow unauthorized modification.
Operational Impact	High	Investigation, recovery and loss of trust may disrupt services.
Overall Risk	High	Sensitive healthcare assets are involved and suspicious activity is already detected.

6. Incident Response Plan

Phase 1 – Identification and Validation

- Validate alerts by correlating authentication logs, EHR audit records, application logs and session information.
- Establish the exact timeline of suspicious events.
- Identify affected accounts, patient records, sessions, devices and network sources.
- Determine whether any unauthorized attempt was successful.
- Preserve relevant logs and evidence before major system changes.

Technical Justification: Evidence correlation prevents incorrect conclusions and ensures response decisions are based on verified indicators.

Phase 2 – Containment

- Temporarily restrict or suspend the suspected account when supported by evidence.
- Revoke active sessions and authentication tokens associated with suspicious activity.
- Require re-authentication before access is restored.
- Increase monitoring of related accounts and EHR resources.
- Block confirmed malicious sources where appropriate.

Technical Justification: Containment reduces continued unauthorized access and prevents suspicious sessions from remaining active.

Phase 3 – Investigation and Eradication

- Review login history, devices, IP information, password resets, MFA events and session records.
- Check for role or permission changes.
- Identify authentication, session-management or authorization weaknesses.
- Remove unauthorized sessions, incorrect privileges and unauthorized access paths.
- Correct the weakness that enabled or contributed to the incident.

Phase 4 – Recovery

- Restore access only after identity verification.
- Reset credentials where compromise is suspected or confirmed.
- Re-establish permissions according to approved job responsibilities.
- Require MFA for future access.
- Closely monitor the account after recovery.

Phase 5 – Post-Incident Review

- Document the timeline, evidence, impact, root cause and response actions.
- Review failed controls and update security policies.
- Improve detection rules for similar EHR activity.
- Conduct lessons learned and assign corrective actions.

7. Prioritized Mitigation Strategies and Justification

Priority 1: Multi-Factor Authentication (MFA)

MFA should be mandatory for doctor accounts and other users accessing sensitive EHR information. Passwords can be exposed or misused; MFA adds another verification layer. Therefore, compromised credentials alone are less likely to result in successful EHR access.

Priority 2: Session Controls

Implement inactivity timeouts, maximum session lifetimes, secure session invalidation, re-authentication for sensitive actions and detection of unusual concurrent sessions. Sessions should be revoked after suspicious activity or credential changes.

Justification: Session controls limit the duration and usefulness of compromised or misused authenticated sessions.

Priority 3: Role-Based Access Control (RBAC) and Least Privilege

Doctor accounts should receive only permissions required for legitimate clinical responsibilities. Access should be restricted to appropriate EHR functions and relevant patient records where supported.

Justification: RBAC limits the information and actions available through a compromised account and directly reduces incident impact.

Priority 4: Audit Monitoring

Maintain centralized and protected audit logs for authentication events, EHR access, authorization decisions, session activity and privilege changes. Configure alerts for repeated failures, unusual access times, abnormal record volume and suspicious concurrent sessions.

Justification: Audit monitoring provides early detection, evidence correlation and reliable support for investigation and response.

Priority 5: Periodic Access Reviews

Regularly review user roles, permissions, inactive accounts and unusual access patterns. This reduces the chance that excessive or outdated permissions remain available.

8. Summary of Major Security Controls

Security Control	Purpose and Technical Justification
MFA	Adds protection beyond passwords and reduces successful account takeover using exposed credentials.
Session Controls	Limits session lifetime and enables rapid invalidation after suspicious activity.
RBAC	Restricts users to approved job-related permissions and limits compromise impact.

Security Control	Purpose and Technical Justification
Audit Monitoring	Provides visibility, evidence correlation, early detection and support for investigation.

9. Conclusion

The repeated unauthorized EHR access attempts through a doctor account represent a high-priority telemedicine security incident. The response should begin with evidence-based validation and rapid containment while preserving evidence. The organization should then identify and correct the contributing authentication, session or authorization weakness before restoring normal access.

MFA, strong session controls, RBAC and continuous audit monitoring provide complementary protection. MFA reduces credential-based account compromise, session controls limit misuse of active sessions, RBAC restricts access according to legitimate responsibilities and audit monitoring improves detection and investigation. Together, these controls reduce both the likelihood and potential impact of future unauthorized EHR access incidents.